

Introduction to Professional Practices in IT

CS4001 – Professional Practices in IT

Asif Fazwani

Data Protection Privacy & Freedom of
Information

DATA PROTECTION & PRIVACY

- Public concern about data protection was first aroused when it was realized that a very large amount of data about individuals was being collected and stored in computers and then used for purposes that were not only different from those intended when the data was collected, but also unacceptable.
- There were also concerns that unauthorized people could access such data and that the data might be out of date, incomplete or just plain wrong.

Example: Cambridge Analytica (2018), Tesco and Sainsbury's (Loyalty Card Data Misuse)

DATA PROTECTION ACT 1984

- These concerns surfaced in the 1970s.
- They were particularly strong in the UK and the rest of Europe and led to a Council of Europe Convention on the subject.
- The first UK Data Protection Act, passed in 1984, was designed to implement the provisions of the Convention.

THE DATA PROTECTION ACT 1984

It was designed to protect individuals from:

- the use of inaccurate personal information or information that is incomplete or irrelevant;
- the use of personal information by unauthorized persons;
- the use of personal information for purposes other than that for which it was collected.

KEY RESPONSIBILITIES

It was meant primarily to protect individuals against the misuse of personal data by large organizations, public or private.

Example :

- Such misuse might occur, for example, if data-matching techniques are used on credit card records to build up a picture of a person's movements over an extended period.
- Further, errors can often creep into data that has been collected or data may be interpreted in a misleading way, and it was difficult to persuade the holders of the data to correct these.
- Credit rating agencies might advise against giving a person a loan because someone who previously lived at the same address defaulted on a loan.

PROGRESSING OF THE ACT

By the mid-1990s, a different danger had become apparent.

- As individuals began to use the internet for an ever-wider range of purposes, it became possible to capture information about the way individuals use the internet and to build profiles of their habits that can be used for marketing purposes and also, perhaps, for more sinister purposes such as blackmail.
- These and other concerns led in 1995 to the European Directive on Data Protection which, in turn, led to the 1998 Data Protection Act.

DATA PROTECTION

- The first UK legislation on data protection was the 1984 Data Protection Act. However, this was taken over by the 1998 Act.
- The Act defines a number of terms that are widely used in discussions of data protection issues. In some cases these are different from the terms used in the 1984 Act.
- To get a clear picture we need to be familiar with some terminologies regarding Data protection

TERMINOLOGY

- **Data** means information that is being processed automatically or is collected with that intention or is recorded as part of a relevant filing system
- **Data controller** means a person who determines why or how personal data is processed. This may be a legal person or a natural person.
- **Data processor**, in this context, means anyone who processes personal data on behalf of the data controller and who is not an employee of the data controller. This might include an application service provider, such as a company that provides online hotel booking services.
- **Personal data** means data which relates to a living person who can be identified from data, possibly taken together with other information the data controller is likely to have or is recorded as part of a relevant filing system.

TERMINOLOGY

- **Data subject** means the individual who is the subject of personal data.
- **Sensitive personal data** means personal data relating to the racial or ethnic origin of data subjects, their political opinions, their religious beliefs, whether they are members of trade unions, their physical or mental health, their sexual life, or whether they have committed or are alleged to have committed any criminal offence. The rules regarding the processing of sensitive personal data are stricter than for other personal data.

PROCESSING

Processing means obtaining, recording or holding the information or data or carrying out any operations on it, including:

- (a) organization, adaptation or alteration of the information or data,
- (b) retrieval, consultation or use of the information or data,
- (c) disclosure of the information or data by transmission, dissemination or otherwise making available, or
- (d) alignment, combination, blocking, erasure or destruction of the information or data.

DATA PROTECTION PRINCIPLES

- The 1998 Act lays down eight data protection principles, which apply to the collection and processing of personal data of any sort.
- Data controllers are responsible for ensuring that these principles are complied with in respect of all the personal data for which they are responsible.

DATA PROTECTION PRINCIPLES

- 1. Lawfulness***
- 2. Purpose***
- 3. Data Minimization***
- 4. Accuracy***
- 5. Storage***
- 6. Security***
- 7. Access***
- 8. Overseas transfer***

DATA PROTECTION PRINCIPLES

1. *Lawfulness*: Personal data shall be processed lawfully, fairly and in a transparent manner in relation to the data subject.

- The GDPR introduced six lawful bases for an organisation being able to process personal data. The ideas of fairness and transparency are key ambitions of the data protection legislation.
- The aim is to have a framework for data processing that enables people to trust the way that organizations process their data.

DATA PROTECTION PRINCIPLES

2. Purpose: Personal data shall be collected for specified, explicit and legitimate purposes and not further processed in a manner that is incompatible with those purposes.

- Data controllers must carefully consider and document the intended purpose or purposes for processing a set of data. There may be times when an organisation processes a set of data that could help it to do something different.
- Example: An e-commerce organisation will typically have address data about its customers so that it can send them their orders. The intended purpose could also include sharing the address data with delivery companies that deliver on behalf of the e-commerce company. The e-commerce company then wants to use those addresses to send marketing information to its customers by post. The e-commerce company would need to check whether its documented purposes allow it to do this. For this example, it is a new purpose that is not covered by the original purpose of fulfilling an order. If the e-commerce organisation wanted to start sending its marketing information, it would need to seek consent from its customers in most cases.

DATA PROTECTION PRINCIPLES

3. *Data minimization*: Personal data shall be adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed.

- Many violations of this principle are due to ignorance rather than an intent. Local government has a bad record of compliance with this principle, for example requiring people wanting to join a public library to state their marital status. Shops that demand to know customers' addresses when goods are not being delivered are also likely to be in breach of this principle. Data controllers need procedures to assess planned data collection, checking what is requested and whether there is an adequate justification for each item of data.

DATA PROTECTION PRINCIPLES

4. Accuracy: Personal data shall be accurate and, where necessary, kept up to date; every reasonable step must be taken to ensure that personal data that are inaccurate, having regard to the purposes for which they are processed, are erased or rectified without delay.

- Data controllers must work to comply with this principle, but it can be difficult to comply in all situations. In the UK, doctors have great difficulty in maintaining up-to-date data about their patients' addresses, particularly patients who are students, because students change their addresses frequently and rarely remember to tell their doctor. Universities have similar difficulties.

DATA PROTECTION PRINCIPLES

5. *Storage:* Personal data shall be kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed; personal data may be stored for longer periods insofar as the personal data will be processed solely for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes.

DATA PROTECTION PRINCIPLES

6. *Security*: Personal data shall be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organizational measures.

DATA PROTECTION PRINCIPLES

7. Access: Appropriate technical and organizational measures shall be taken against unauthorized or unlawful processing of personal data and against accidental loss or destruction of, or damage to, personal data. It implies the need for access control (through passwords or other means), backup procedures, integrity checks on the data, vetting of personnel who have access to the data, and so on.

DATA PROTECTION PRINCIPLES

8. *Overseas transfer:* Personal data shall not be transferred to a country or territory outside the European Economic Area unless that country or territory ensures an adequate level of protection for the rights and freedoms of data subjects in relation to the processing of personal data.

RIGHTS OF DATA SUBJECTS

- The 1984 Act gave data subjects the right to know whether a data controller held data relating to them, the right to see the data, and the right to have the data erased or corrected if it is inaccurate.
- The 1998 Act extends this right of access so that data subjects have the right to receive:
 - a description of the personal data being held;
 - an explanation of the purpose for which it is being held and processed;
 - a description of the people or organizations to which it may be disclosed;
 - an intelligible statement of the specific data held about them;
 - a description of the source of the data.

PRIVACY

- The starting point is the Regulation of Investigatory Powers Act 2000, which sets up a framework for controlling the lawful interception of computer, telephone and postal communications.
- The Act allows government security services and law enforcement authorities to intercept, monitor and investigate electronic data only in certain specified situations such as when preventing and detecting crime. Powers include being able to demand the disclosure of data encryption keys.

PRIVACY

Under the Act and the associated regulations, organizations that provide computer and telephone services (this includes not only ISPs (internet service providers) and other telecommunications service providers but also most employers) can monitor and record communications without the consent of the users of the service, provided this is done for one of the following purposes:

- to establish facts, for example, on what date a specific order was placed;
- to ensure that the organization's regulations and procedures are being complied with;
- to ascertain or demonstrate standards which are or ought be to be achieved;
- to prevent or detect crime (whether computer-related or not);
- to investigate or detect unauthorized use of telecommunication systems;
- to ensure the effective operation of the system, for example, by detecting viruses or denial of service attacks;

PRIVACY

- To find out whether a communication is a business communication or a private one (e.g. monitoring the emails of employees who are on holiday, in order to deal with any that relate to the business);
- To monitor (but not record) calls to confidential, counselling helplines run free of charge by the business, provided that users are able to remain anonymous if they so choose.

FREEDOM OF INFORMATION

Feature: General Right of Access

Public authorities must provide access to information they hold, unless an exemption applies.

Example:

- A citizen asks the **Department of Education** for statistics on school dropout rates.
- The department must provide the information because it is not sensitive or exempt.

FREEDOM OF INFORMATION

Feature: Duty to Disclose if Public Interest Outweighs Exemption

Even if information is exempt, it may still need to be disclosed when the **public interest in disclosure > public interest in withholding**.

Example

- A council receives a request for a report on safety issues in a public housing project.
- Even though the report contains internal deliberations (normally exempt), the risk to public safety means **public interest favours disclosure**.

FREEDOM OF INFORMATION

Feature: Publication Scheme Requirement

Authorities must publish certain categories of information proactively through a **Publication Scheme** approved by the ICO (Information Commission Office)

Example

- A city council's website publishes:
 - Annual budgets
 - Minutes of council meetings
 - Staff structure charts
 - Fees for services
- These are accessible **without needing to submit an FOI request.**

Question 1

Which data protection principles are potentially breached when CSTC shares learners' assessment scores with the employer without informing them?

Answer: Sharing learners' assessment scores with an employer without informing them breaches:

Lawfulness, fairness, and transparency – learners were not told about this use of their data.

Purpose limitation – data collected for training was used for a different, unrelated purpose.

Question 2

The spreadsheet includes data of learners who left two years ago. Which principle does this violate and why?

Answer: Keeping data of learners who left two years ago breaches:

- **Storage limitation** – data must not be kept longer than necessary.
CSTC should have deleted or archived this data according to a retention schedule.

Question 3

Is it appropriate for all 10 administrative staff to have access to personal data? Which principle applies?

Answer: Allowing all 10 administrative staff to access all learner data breaches:

- **Data minimisation** – only staff who *need* access should have it.
- **Integrity and confidentiality** – access should be restricted to protect security.

CLASS ACTIVITY 8

<https://tinyurl.com/Fall2025-Activity8>